



ЦЕЛЕНАПРАВЛЕННЫЕ АТАКИ

ПРАКТИЧЕСКОЕ ЗАДАНИЕ: ЗАЩИТНЫЕ МЕХАНИЗМЫ

Выполнил: Юрий Шамрай (MIFIIB/1-й поток)

ЦЕЛЬ ПРАКТИЧЕСКОГО ЗАДАНИЯ:

Построить систему защиты: подобрать классы используемых средств защиты информации.

ЧТО НУЖНО СДЕЛАТЬ:

Предоставьте отчёт в виде решений по обеспечению информационной безопасности, таких как:

- Разделение локальных сетей;
- Обучение пользователей;
- Установка сетевых средств защиты информации;
- Установка хостовых средств защиты информации;
- Другие решения.

УСЛОВИЯ ЗАДАЧИ:

Дана коммерческая организаций, которая занимается грузоперевозками. В организации есть несколько отделов:

- Менеджеры по грузоперевозкам;
- Бухгалтерия;
- Кадровая служба;
- Служба ИТ.

Дополнительная информация, которая вам известна:

- Есть сайт, размещённый на собственных мощностях;
- DMZ-зона отсутствует;
- Сотрудников с удалённым доступом нет;
- Менеджеры звонят с использование IP-телефонии.

Дополнительно вам известна только матрица атаки из практического задания «Создание тактики реализации компьютерной атаки».

ЗАДАЧА:

- Составьте список средств защиты информации, которые вы можете предложить для нейтрализации атаки;
- Необходимо предусмотреть:
 - ✓ Организационные меры защиты (обучение персонала);
 - ✓ Технические меры защиты (разделение сетей).
- Дополнительное условие: предложенные средства защиты информации должны быть указаны с названием вендора и модели. Также должны быть прописаны номера этапов в вашем сценарии (согласно матрице MITRE), которые перекрываются данным средством защиты, например:
 - ✓ Межсетевой экран CheckPoint перекрывает этап 3 – «Первоначальный доступ».

ВВЕДЕНИЕ

Целью данного практического задания является построение системы защиты информации для коммерческой организации, специализирующейся на грузоперевозках. Наша задача состоит в предложении мер и решений, направленных на обеспечение безопасности данных и защиты от возможных кибератак.

Для успешной защиты организации рассмотрим различные аспекты информационной безопасности, включая обучение персонала, разделение локальных сетей, установку сетевых и хостовых средств защиты информации, а также другие технические и организационные меры. Дополнительно, учитывая матрицу атак (MITRE ATT&CK), мы свяжем каждую предложенную меру с соответствующими этапами из этой матрицы.

С учетом дополнительных условий, таких как отсутствие DMZ-зоны и удаленного доступа сотрудников, а также знание структуры организации и специфики ее деятельности, разработаем и рекомендуем оптимальные решения для обеспечения надежной защиты данных организации и предотвращения возможных угроз.

ВЫПОЛНЕНИЕ

Данные о Компании и связи отделов с информационной безопасностью:

Компания, занимающаяся грузоперевозками, представляет собой коммерческую организацию с разнообразными отделами, каждый из которых выполняет важные функции для эффективного функционирования компании.

Ниже предоставлено более подробное описание каждого отдела и их связи с информационной безопасностью ☒

1. Менеджеры по грузоперевозкам:

- Отдел менеджеров по грузоперевозкам ответственен за управление логистикой, планирование маршрутов, координацию перевозок и общение с клиентами. Они могут иметь доступ к конфиденциальной информации о грузах, контрагентах, маршрутах, стоимости услуг, договорах и других коммерческих данных.
- ☒ Все сотрудники этого отдела должны быть осведомлены о политиках и процедурах безопасности компании, а также обучены правильному обращению с конфиденциальной информацией. Ограничение доступа к чувствительным данным и применение аутентификации могут помочь предотвратить несанкционированный доступ к коммерческой информации.

2. Бухгалтерия:

- Бухгалтерия занимается управлением финансовыми операциями компании, включая обработку счетов, платежей, учет расходов и доходов, а также подготовку отчетности. В данном отделе содержится финансовая информация о компании и её клиентах.
- ☒ Этот отдел обрабатывает финансовые данные, и поэтому особое внимание должно уделяться безопасности данных и защите от финансового мошенничества. Шифрование данных, многофакторная аутентификация, регулярный аудит доступа и другие меры обеспечения безопасности помогут защитить финансовую информацию.

3. Кадровая служба:

- Отдел кадров отвечает за управление персоналом, найм, увольнение, заработную плату, налогообложение и хранение личных данных сотрудников. Кадровая служба обладает доступом к конфиденциальным данным о сотрудниках, включая персональные данные, медицинские записи, финансовую информацию и т. д.
- ☒ Кадровая служба обрабатывает личные данные сотрудников, что делает этот отдел очень уязвимым для утечек данных и идентификационного мошенничества. Ограничение доступа к личным данным, регулярное обучение сотрудников кадровой службы о процедурах безопасности и применение шифрования помогут снизить риски нарушения безопасности.

4. Служба ИТ:

- Отдел информационных технологий (ИТ) отвечает за управление и обслуживание компьютеров, серверов, сетей, программного обеспечения и других технических аспектов компании. Он также занимается кибербезопасностью и обеспечением защиты сетевых ресурсов.
- ☑ Отдел ИТ играет критическую роль в обеспечении безопасности информационной инфраструктуры компании. Он должен устанавливать и обновлять меры безопасности, включая межсетевые экраны, антивирусное программное обеспечение, системы обнаружения вторжений (IDS/IPS) и т. д. Также отдел ИТ обязан обучать сотрудников безопасности информационной технологии и управлять уязвимостями в сетевой инфраструктуре.

5. Веб-сайт и его безопасность:

- Веб-сайт компании представляет собой важный инструмент для привлечения клиентов и обеспечения коммуникации с ними. Безопасность сайта крайне важна для предотвращения взлома и уязвимостей, которые могут привести к утечке данных клиентов или компрометации сайта.
- ☑ Отдел ИТ должен обеспечить безопасность веб-сайта, используя обновления программного обеспечения, межсетевые экраны, шифрование данных и другие меры безопасности. Регулярное тестирование уязвимостей сайта поможет обнаружить потенциальные уязвимости и устранить их.

6. IP-телефония:

- Использование IP-телефонии менеджерами предоставляет потенциальные риски для безопасности. Атаки на IP-телефонию могут привести к перехвату разговоров, подделке номера и другим видам социальной инженерии.
- ☑ Для обеспечения безопасности IP-телефонии отдел ИТ должен принять меры, такие как использование шифрования для голосовых данных, контроль доступа к телефонным системам и мониторинг активности для обнаружения аномалий.

Все отделы компании играют важную роль в обеспечении информационной безопасности. Внедрение соответствующих политик, процедур и обучение сотрудников в области кибербезопасности являются важными мерами для защиты данных компании и предотвращения кибератак. Сотрудничество между отделами и понимание их взаимосвязи с информационной безопасностью помогут обеспечить более надежную защиту компании от потенциальных угроз.

Построение системы защиты информации:

Для построения системы защиты следует начать с проведения комплексного анализа информационной безопасности организации. Этот анализ поможет определить текущее состояние безопасности, выявить уязвимости и риски, а также определить необходимые меры для улучшения защиты. Вот основные шаги, с которых стоит начать:

1. **Проведение аудита безопасности:** необходимо оценить текущее состояние безопасности в организации. Это включает проверку сетевой инфраструктуры, наличие уязвимостей в системах, политики доступа, уровень обучения сотрудников и другие аспекты, которые могут повлиять на безопасность.
2. **Идентификация активов и критических данных:** определить, какие данные и ресурсы являются наиболее ценными для организации. Это поможет сосредоточить усилия на защите наиболее важных активов.
3. **Разработка политик безопасности:** создание набора правил и политик, которые определяют стандарты безопасности для организации. Это может включать политику паролей, политику доступа к данным, правила использования сети и т. д.
4. **Обучение персонала:** проводим обучение сотрудников по правилам безопасности, угрозам информационной безопасности и методам защиты от атак. Обученный персонал является ключевым звеном в обеспечении безопасности организации.

Далее, мы подробнее рассмотрим и определим различные организационные меры защиты информации и рекомендации по их внедрению в рамках данного практического задания.

Организационные меры защиты:

Организационные меры защиты являются важным аспектом обеспечения информационной безопасности организации. Эти меры включают в себя создание различных политик, процедур и правил, которые регулируют поведение сотрудников, обеспечивают безопасное использование информационных ресурсов и минимизируют угрозы для компании. Рассмотрим несколько основных политик, которые можно реализовать:

- 1. Политика паролей:** эта политика устанавливает требования к созданию и использованию паролей сотрудниками.
 - Установить минимальную длину пароля (например, не менее 12 символов);
 - Требовать использование букв в разных регистрах, цифр и специальных символов;
 - Запрещать использование очень простых паролей (например, "123456" или "password");
 - Периодичность смены паролей (например, каждые 90 дней).
- 2. Политика доступа к данным:** эта политика определяет, кто и при каких условиях имеет доступ к различным данным и ресурсам организации.
 - Определить уровни доступа для разных ролей сотрудников (например, администраторы, менеджеры, обычные пользователи);
 - Ограничить доступ к чувствительным данным только тем сотрудникам, которым это необходимо для выполнения своих обязанностей;
 - Разработать процедуры для предоставления и отзыва доступа при изменении ролей сотрудников.
- 3. Политика управления устройствами:** установить правила использования персональных устройств сотрудников (например, смартфонов, планшетов) на рабочем месте.
 - Определить правила использования персональных устройств в сети организации;
 - Разработать процедуры для удаленного управления и блокировки утерянных или украденных устройств.
- 4. Политика управления программным обеспечением:** эта политика определяет правила установки и использования программного обеспечения на компьютерах организации.
 - Разрешить установку только лицензированного и авторизованного программного обеспечения;
 - Запретить самостоятельную установку программного обеспечения пользователями.
- 5. Политика управления сетью:** определить правила использования сети организации и обеспечить ее безопасность.
 - Ограничить доступ к сети организации только авторизованным устройствам;
 - Установить брандмауэр для мониторинга и фильтрации трафика в сети;
 - Разработать процедуры для обнаружения и блокировки подозрительной активности на сети.
- 6. Политика обучения пользователей:** эта политика определяет требования к обучению сотрудников в области информационной безопасности.
 - Организовать регулярные тренинги и семинары для сотрудников по темам безопасности (например, как распознавать фишинговые письма или как обрабатывать конфиденциальные данные);
 - Предоставить сотрудникам ресурсы и материалы для самостоятельного обучения вопросам безопасности;
 - Обязать новых сотрудников проходить обучение безопасности при принятии на работу.

Каждая из этих политик должна быть разработана с учетом конкретных потребностей и особенностей организации, а также соответствовать законодательству и промышленным стандартам в области информационной безопасности. Регулярное обновление и проверка соответствия политик также являются важными аспектами обеспечения эффективной защиты информации.

Технические меры защиты:

После определения организационных мер защиты информации, наш следующий шаг состоит в рассмотрении технических мер. Технические меры защиты представляют собой использование специализированных технологий и средств для обеспечения безопасности информации и инфраструктуры организации. Они направлены на защиту компьютерных систем, сетей, данных и приложений от угроз и атак. В данном контексте технические меры являются ключевой составляющей современных систем безопасности и позволяют создать надежный барьер против внешних и внутренних угроз.

Далее, мы более подробно рассмотрим и определим различные технические меры защиты информации и практические рекомендации по их применению в организации.

- **Межсетевой экран (Firewall):** представляет собой систему фильтрации сетевого трафика, которая контролирует и ограничивает доступ к сети извне. Он позволяет разрешать или блокировать сетевые соединения на основе определенных правил и политик безопасности.
 - Установка межсетевого экрана на границе сети. Настройка его согласно бизнес-требованиям и политикам безопасности. Определить разрешенные и запрещенные типы трафика, разрешить доступ только для необходимых сетевых служб и портов.
- **Системы обнаружения (IDS/IPS) предотвращения вторжений:** предназначены для обнаружения и предотвращения попыток несанкционированного доступа и вторжений в сеть и системы организации.
 - Развернуть IDS/IPS в сети для постоянного мониторинга сетевого трафика и обнаружения подозрительной активности. Настроить системы для реагирования на потенциальные угрозы, блокируя или предотвращая атаки.
- **Разделение сетей на VLAN (виртуальные локальные сети):** это позволяет разграничить трафик между различными сегментами сети, уменьшая возможности для несанкционированного доступа и распространения угроз по сети.
 - Разделить сеть на логические VLAN, отражающие структуру организации и доступ пользователей к различным ресурсам. Установить контроль доступа на маршрутизаторах и коммутаторах для обеспечения изоляции между VLAN и ограничения трафика между ними.
- **Антивирусное программное обеспечение:** предназначено для обнаружения и блокировки вредоносных программ, таких как вирусы, троянские программы и шпионское ПО, чтобы предотвратить их воздействие на компьютеры и сеть.
 - Установить антивирусное программное обеспечение на все компьютеры и серверы в сети. Регулярно обновлять его базы данных и настроить автоматическое сканирование на предмет вредоносных программ.
- **Двухфакторная аутентификация:** требует от пользователей предоставления двух различных форм подтверждения своей личности для доступа к системам и данным.
 - Внедрить двухфакторную аутентификацию для всех критических систем и приложений. Использовать комбинацию пароля и одноразового кода, SMS-подтверждения или аппаратного токена для повышения уровня безопасности.
- **Шифрование данных:** обеспечивает конфиденциальность информации, делая ее непонятной для неавторизованных лиц даже при несанкционированном доступе.
 - Применять шифрование для хранения конфиденциальных данных, особенно при передаче данных через небезопасные сети. Использование SSL/TLS для шифрования сетевого трафика, и внедрение полного дискового шифрования для защиты хранимых данных.
- **Резервное копирование данных:** регулярное резервное копирование данных помогает предотвратить потерю информации в случае сбоя системы, атаки или катастрофы.
 - Установить регулярное расписание резервного копирования всех критических данных. Хранить резервные копии в отдельных безопасных хранилищах, доступных только авторизованным лицам.

Каждое техническое решение должно быть интегрировано в общую стратегию безопасности и должно отражать особенности и требования организации. Кроме того, важно постоянно мониторить и анализировать безопасность, чтобы реагировать на новые угрозы и атаки.

Список средств защиты информации:

Далее, рассмотрим комплексные решения защиты информации, для нейтрализации атак на каждом из этапов матрицы MITRE ATT&CK. Все перечисленные средства представлены с указанием названия вендора и модели, а также сопоставлены с этапами атак, на которые они оказывают наибольшее влияние.

➤ [Palo Alto Networks Next-Generation Firewall:](#)

- ✓ Разведка/Подготовка ресурсов/Первоначальный доступ/Предотвращение обнаружения/Управление и контроль
 - Это современный брандмауэр следующего поколения, который обеспечивает защиту сети от различных угроз, обнаруживает и блокирует вредоносный трафик, контролирует доступ к ресурсам сети, предоставляет функции межсетевого экранирования и SSL-дешифрования, а также интегрируется с системами SIEM для централизованного мониторинга.

➤ [Endpoint Protector от CoSoSys:](#)

- ✓ Выполнение/Экспфильтрация данных
 - Обеспечивает контроль и защиту конфиденциальных данных на конечных точках, предотвращая утечку информации через USB-устройства, веб-приложения, облачные сервисы и другие каналы. Он позволяет контролировать и мониторить поток данных, блокируя возможные источники утечек.

➤ [Cisco Identity Services Engine \(ISE\):](#)

- ✓ Закрепление/Перемещение внутри периметра
 - Это решение для контроля доступа к сети, которое обеспечивает автоматизированный процесс аутентификации и авторизации пользователей и устройств, а также обеспечивает контроль и сегментацию сетевого трафика на основе ролей и политик.

➤ [Veeam Backup and Recovery:](#)

- ✓ Воздействие
 - Резервное копирование и восстановления данных, обеспечивает защиту от уничтожения данных, в том числе от случайного или злонамеренного удаления, а также от атак типа "Ransomware".

➤ [Splunk Enterprise с интеграцией с Darktrace:](#)

- ✓ Разведка/Предотвращение обнаружения/Исследование
 - Splunk Enterprise — это система сбора и анализа данных, которая позволяет обнаруживать аномальное поведение и атаки в реальном времени. Интеграция с Darktrace – это система искусственного интеллекта для обнаружения внутренних угроз и аномалий в сети.

➤ [CrowdStrike Falcon Endpoint Protection Platform:](#)

- ✓ Выполнение/Повышение привилегий/Предотвращение обнаружения
 - Предоставляет расширенную защиту от современных угроз на конечных точках. Он использует искусственный интеллект и машинное обучение для выявления и предотвращения атак, а также обеспечивает контроль над поведением и действиями вредоносных программ на конечных точках.

ЗАКЛЮЧЕНИЕ

В ходе выполнения практического задания "Защитные механизмы" был разработан комплексный план мер по обеспечению безопасности в организации, занимающейся грузоперевозками. Также, были предложены организационные меры защиты, включая обучение персонала. Эти меры позволят повысить осведомленность сотрудников об угрозах информационной безопасности и улучшить управление доступом к ресурсам.

Мы проанализировали матрицу MITRE ATT&CK, идентифицировали основные этапы атаки, на которые необходимо обратить особое внимание при разработке системы защиты и составили рекомендуемый список средств защиты информации.

ПРАКТИЧЕСКАЯ РАБОТА ЗАВЕРШЕНА!